

FootPrinting [Client Redacted]

Date: April 23, 2026

Subject: Active and Defensive Cybersecurity

Lecturer: Carlos Antunes

Team: João Marto

Table of Contents

1.Organizational Information	3
2.Network Footprinting and Asset Mapping.....	4
2.1.Domain Identification and Administrative Records.....	5
2.2.DNS infrastructure	5
2.3.Attack Surface Enumeration (via Automation).....	5
2.4.Conclusions of the Recognition Phase.....	6
3.Scanning and Analysis Services.....	7
3.1.Active Ports and Protocols.....	8
3.2.Fingerprinting Technologies.....	8
3.3.SSL/TLS Certificate Analysis.....	9
3.4.Conclusions and Attack Vectors.....	10
4.Data Intelligence and Information Leaks.....	11
4.1.Identification of Exposed Files.....	11
4.2.Risk Assessment	12
5.Summary of Risks and Attack Surface.....	13
5.1.Risk Matrix (Probability vs. Impact).....	13
6.Mitigation Measures and Recommendations.....	14
6.1.Technical Protection Measures (Infrastructure)	14
6.2.Organizational and Management Measures.....	15
6.3.Measures Relating to the Human Factor	15
7.WebGrafia.....	16
8.Command Log.....	17

1. Organizational Information



Company Name: [Client Redacted]

NIF: [Client Redacted]

Head Office Address: [Client Redacted]

Branch: [Client Redacted]

CAE (Economic Activity Code): [Client Redacted]

Digital Presence:

- **Domain:** [Client Redacted]
- **Facebook:** [Client Redacted]

2. Network Footprinting and Asset Mapping

In this initial phase of recognition, the objective was to map the organization's external digital presence and identify its public technological infrastructure, combining passive information collection techniques with active validation.

2.1. Domain Identification and Administrative Records

The initial analysis began by identifying the main domains operated by the entity. Through OSINT searches and queries of WHOIS records, it was possible to draw the following administrative profile:

- **Identified Domains:** [Client Redacted] and [Client Redacted]
- **Technical Contact Information:** Registrant data is hidden by privacy mechanisms (GDPR Masked), which is a standard security practice that prevents the collection of emails or names of administrators for potential social engineering attacks.

2.2. DNS infrastructure

The interrogation of the domain authority records revealed that the management of DNS zones is delegated to an external entity. The official name servers identified were:

-
-

2.3. Attack Surface Enumeration (via Automation)

To discover undocumented assets, subdomains were enumerated. To ensure the reliability of the data, a proprietary automation script was used (the source code and execution methodology are detailed in Chapter 4: Command Logging).

This script cross-referenced data from reconnaissance tools and actively validated the existence of IPs, resulting in the discovery of 9 operational assets. The table below presents the network mapping:

Active (Subdomain)	IP address	Category
	[IP Redacted]	Main Domain
	[IP Redacted]	Public Web Presence
mail.	[IP Redacted]	Email Server
webmail.	[IP Redacted]	Email Web Interface
autodiscover.	[IP Redacted]	Automatic Configuration of E-mail Clients
cpanel.	[IP Redacted]	Server Admin Panel
webdisk.	[IP Redacted]	File Storage and Sharing
cpcalendars.	[IP Redacted]	Synchronization Service (Calendars)
cpcontacts.	[IP Redacted]	Sync Service (Contacts)

2.4. Conclusions of the Recognition Phase

The analysis of the data obtained allows us to draw critical conclusions for the *subsequent Scanning* phase :

1. **Centralized Architecture:** All 9 resolved subdomains point to a single IP address ([IP Redacted]), belonging to the *PT Web Server* network. This indicates a shared hosting environment or a single dedicated server. A Single Point of Failure means that a successful attack on this IP would simultaneously compromise the company's website, email, and files.
2. **Exposure of Management Panels:** The identification of inputs such as cpanel and webdisk demonstrates that the infrastructure administration interfaces are exposed to the public internet. These interfaces represent high-priority attack vectors for brute force testing or exploitation of known vulnerabilities in management software.

3. Scanning and Analysis Services

In this phase, the analysis focused on the assets identified in the network footprinting, using the **Censys** platform to carry out a passive and detailed survey of the exposed services and support technologies. This approach allows you to obtain technical data without alerting the target's intrusion monitoring systems.

3.1. Active Ports and Protocols

Analysis of the web properties in Censys confirmed that the domain-joined server **[IP Redacted]** has the following open default ports:

- **Port 80 (HTTP):** Available for unencrypted web traffic.
- **Port 443 (HTTPS):** Active for secure communications, featuring a Trusted configuration.

3.2. Fingerprinting Technologies

Analysis of the software fields and headers allowed us to accurately identify the organization's supporting infrastructure:

- **Web Server (Nginx):** It is the software responsible for delivering the pages of the website to visitors. The fact that it appears as Nginx indicates that the site uses modern and fast technology to manage traffic.

- **Programming Language (PHP):** It is the "language" that the server speaks to process the information of the website. Identifying PHP is important because it tells us what kind of scripts and code are running behind the scenes.
- **Identity Confirmation (HTML):** The title found in the searches ([IP Redacted]) gives us absolute certainty that this server really belongs to the target company and is not a false positive.

3.3. SSL/TLS Certificate Analysis

The analysis of the site's security "padlock" through Censys allowed us to understand how the company protects its communications:

- **Provider (Let's Encrypt):** The company uses *Let's Encrypt* to issue its security certificates. It is a service that ensures that the connection between the user and the server is encrypted and secure.
- **General Certificate (Wildcard):** The use of a certificate for *[IP Redacted] has been detected. The * symbol acts as a "wildcard," meaning that this single certificate protects the main site and all other services (such as email or management panels) at once.
- **Validity:** The current certificate is correct and is valid until 05/05/2026. Because the status is "Trusted", browsers do not show danger warnings to visitors.

- **Digital Trail (History):** Censys stores the history of all the certificates that the company has used. Even old or expired certificates are useful in this analysis, as they work as clues to find names of servers or services that the company used in the past and that may still be active.

3.4. Conclusions and Attack Vectors

Technical analysis through Censys reveals a well-configured but transparent attack surface:

1. **Stack Visibility:** The exposure that the server runs Nginx and PHP allows an attacker to perform *vulnerability research* targeting CVEs specific to these technologies.
2. **Concentration of Services:** As identified in Chapter 2, the technology stack is shared by all subdomains (cPanel, Webmail, etc.). A vulnerability found in the PHP service or a misconfiguration in Nginx would have a systemic impact on all [Client Redacted] assets.
3. **Perimeter Security:** The use of F5 infrastructure suggests that denial-of-service (DoS) attacks or simple web attacks can be filtered out, forcing a more sophisticated exploitation phase.



ESCOLA SUPERIOR
DE TECNOLOGIA
E GESTÃO



4. Data Intelligence and Information Leaks

At this stage, the analysis stopped focusing only on the physical infrastructure and moved on to the research of **exposed data**. To do this, the **Intelligence X** platform was used, a search engine specializing in Dark Web files, data *breaches*, and public text repositories (such as Pastebin).

4.1. Identification of Exposed Files

Research has revealed that [IP Redacted] (or references to your domain) is present in at least **19 text files, 4 CSV files, and 3 databases**. The following records stand out:

- **Large-Scale Corporate Listings:** The domain appears in a file called 49M BASE CORP UHQ.csv. This indicates that company data (most likely contacts or tax data) is part of massive lists of companies that are shared or sold online for marketing purposes or targeted attacks.
- **External SQL Databases:** A reference was found in the mbeadmin.com.sql. The presence in a database file (.sql) of another domain suggests a technical link or a data leak where the company's information was stored.



ESCOLA SUPERIOR
DE TECNOLOGIA
E GESTÃO



- **Business Intelligence Archives:** Mentions were detected in files from **Bureau van Dijk (BvD)**, a business data platform. This confirms that the company is mapped in global corporate intelligence databases.

4.2. Risk Assessment

Based on these results, we identified the following risks for the company:

1. **Exposure on Spam and Phishing Lists:** Being present on lists of "49 million companies" means that [Client Redacted] emails are in the hands of those who send spam attacks or fraud attempts.
2. **Technical Data Trail:** Appearing in .sql files can reveal relationships between the company and software vendors or partners that have experienced information leaks in the past.
3. **Data Hygiene:** While many of these lists contain information that may be public (such as VAT number or address), their aggregation into "Leaks" files makes life easier for an attacker who wants to create a complete company profile for a social engineering attack.



ESCOLA SUPERIOR
DE TECNOLOGIA
E GESTÃO



5. Summary of Risks and Attack Surface

Before moving on to recommendations, it is necessary to classify the risks identified during *the footprinting* to prioritize defense actions.

5.1. Risk Matrix (Probability vs. Impact)

Based on the assets found (cPanel, Webmail, IntelX leaks), we classified the threats as follows:

Threat Identified	Probability	Impact	Risk Level
Brute Force Attack (cPanel/Webmail)	High	Critical	CRITICAL ACT
Targeted phishing (via IntelX leaks)	High	Medium	HIGH
Exploiting flaws in PHP/Nginx	Average	High	HIGH
Unavailability due to single IP failure	Low	Critical	MEDIUM



ESCOLA SUPERIOR
DE TECNOLOGIA
E GESTÃO



6. Mitigation Measures and Recommendations

Based on the risks identified in the *Footprinting phases*, the following measures are suggested to strengthen [Client Redacted]'s cybersecurity posture

6.1. Technical Protection Measures (Infrastructure)

- **Implementation of Second-Factor Authentication (MFA/2FA):** Mandatory activation of two-factor authentication at all exposed entry points, especially in **cPanel** and **Webmail**. This ensures that even if a password is discovered (via IntelX or Brute Force), the attacker will not be able to log in.
- **Hardening:** Configure **the Nginx** server and **PHP** not to display their versions in the response headers (e.g. disable `server_tokens`). This makes it difficult for attackers to search for specific flaws (CVEs).
- **Using a CDN/WAF (e.g. Cloudflare):** Placing the website behind a service like Cloudflare to hide the real IP address ([IP Redacted]). This helps prevent Denial of Service (DDoS) attacks and makes it difficult to map the infrastructure directly.



ESCOLA SUPERIOR
DE TECNOLOGIA
E GESTÃO



- **Email Security Configuration (SPF, DKIM and DMARC):** Validate and enforce these DNS records to prevent third parties from sending fake emails on behalf of @[Client Redacted], protecting the company's reputation and preventing scams.

6.2. Organizational and Management Measures

- **Business Continuity Plan (Backups):** Given the risk of "Single Point of Failure" (SPOF), it is essential to ensure that up-to-date backups exist outside of the primary server. We recommend the

3-2-1 rule: 3 copies, on 2 different media, with 1 copy *offline* or in another geographical location.

- **Password Management Policy:** Establish an internal standard that prohibits the reuse of personal passwords in company services. As we saw in Intelligence X, data leaks on external websites are common and can compromise the company's access.

6.3. Measures Relating to the Human Factor

- **Phishing Awareness Training:** Conduct short training sessions for employees at headquarters (Lisbon) and branch (Porto de Mós), teaching them how to identify suspicious emails that use the names of partners or technical terms of the company.
- **Physical Security Control at the Branch:** Reinforce security procedures in Porto de Mós, ensuring that access to the internal Wi-Fi network is restricted and that sensitive equipment (local routers/servers) are not visible or accessible to the public visiting the store.



ESCOLA SUPERIOR
DE TECNOLOGIA
E GESTÃO



7. WebGrafia

[https://\[Client Redacted\]/](https://[Client Redacted]/)

[https://www.racius.com/\[Client Redacted\]/](https://www.racius.com/[Client Redacted]/)

[https://platform.censys.io/search?q=%22\[Client Redacted\] %22](https://platform.censys.io/search?q=%22[Client Redacted]%22)

[https://intelx.io/?s=\[Client Redacted\]](https://intelx.io/?s=[Client Redacted])

[https://builtwith.com/\[Client Redacted\]](https://builtwith.com/[Client Redacted])

<https://hunter.io>

[https://intelx.io/?s=https%3A%2F%2Fwww. \[Client Redacted\] %2F](https://intelx.io/?s=https%3A%2F%2Fwww.[Client Redacted] %2F)



ESCOLA SUPERIOR
DE TECNOLOGIA
E GESTÃO



8. Command Log

ping [Client Redacted]

whois [Client Redacted]

./subfinder.sh (script created by me)

```
#!/bin/bash

TARGET=$1

if [ -z "$ALVO" ]; then
    echo "Usage: $0 <domain>"
```

```

        exit 1
    fi

    NAMESERVERS=$(dig ns "$ALVO" +short)
    if [ -z "$NAMESERVERS" ]; then
        NAMESERVERS="8.8.8.8"
        echo "NS not found. Using Google DNS."
    fi

    echo "Searching for subdomains (Subfinder + Sublist3r)..."

    temp_subs="bruto_subs.txt"
    > "$temp_subs"

    for i in {1..2}; of the
        echo "Execution $i/2..."
        subfinder -d "$ALVO" -silent >> "$temp_subs"
        sublist3r -d "$ALVO" -o temp_subl.txt > /dev/null
        if [ -f temp_subl.txt ]; then
            cat temp_subl.txt >> "$temp_subs"
            rm temp_subl.txt
        fi
    done

    sort -u "$temp_subs" > subdominio.txt
    rm "$temp_subs"

    total=$(wc -l < subdominio.txt)
    echo "Unique $total subdomains were found."

    echo "Resolving IPs..."
    > resolvidos.txt
    declare -a visas

    while read -r sub; of the
        for NS in $NAMESERVERS; of the
            ip=$(dig @"$NS" "$sub" +short | grep -E '[0-9.]+\.' | tail -n1)
            if [ -n "$ip" ]; then
                result="$sub : $ip"
                if [ -z "${visas["$result"]}" ]; then
                    echo "$result" | tee resolvidos.txt
                    visas["$result"]=1
                fi
            fi
            break
        fi
    done
done < subdominio.txt

echo "Process finished. Results in resolvidos.txt"

```